

O que realmente está exposto?

Ativos, ameaças e vulnerabilidades

Guia de condução para um encontro de 104 minutos que parte de uma resposta HTTP observável, constrói vocabulário técnico somente quando necessário e termina com um registro de vulnerabilidade defensável.

Carga	Turma	Cenário	Produto
52 min conceituais + 52 min práticos	duplas com papéis rotativos	OWASP Juice Shop local e autorizado	inventário + ticket + reteste

Visão do encontro

A equipe de uma empresa fictícia acaba de disponibilizar uma loja de testes. O catálogo funciona, mas uma requisição retorna um arquivo que deveria permanecer interno. A turma não recebe imediatamente o diagnóstico. Ela precisa estabelecer o que foi observado, identificar os ativos envolvidos, formular hipóteses de fraqueza e justificar qual consequência merece prioridade.

A aula desloca o foco da obtenção de uma flag para uma tarefa profissional: produzir evidência que outra equipe consiga revisar e retestar. O Juice Shop dá concretude à situação, mas não é o objetivo final. O resultado é a capacidade de conectar evidência, conceito, impacto, ação e validação.

PERGUNTA MOBILIZADORA

O servidor entregou um recurso com HTTP 200. O que podemos afirmar, o que ainda é hipótese e qual consequência justifica agir primeiro?

Resultados observáveis

- Inventariar os ativos do Juice Shop relacionando função, responsável, dependências e consequência; comparar OT somente na transferência.
- Distinguir ameaça, fraqueza, vulnerabilidade, exposição, exploit, CWE e CVE no mesmo caso.
- Produzir um registro com evidência interpretada, prioridade, controle condicionado e reteste verificável.

1. Preparação do professor

Ambiente e materiais

- Abrir a apresentação A02 e testar a legibilidade no projetor.
- Disponibilizar o PDF prático no Classroom, mas pedir que a turma não avance antes da transição do slide 8.
- Orientar cada estudante a executar seu próprio Juice Shop local. Escrever no quadro: `http://127.0.0.1:3000`.
- Confirmar previamente Docker Desktop no Windows em modo Linux containers ou Docker Engine no Linux.
- Baixar a imagem antes do encontro quando a rede do laboratório for limitada.
- Confirmar que DevTools permite observar a requisição. Burp Community é opcional e não deve ser pré-requisito.
- Validar a rota escolhida na versão instalada. Não assumir que telas e desafios permanecem iguais entre versões.
- Manter a evidência alternativa do roteiro pronta: requisição fictícia, resposta 200 e tipo de conteúdo.

Comandos que devem permanecer visíveis

PowerShell do Windows e terminal Linux usam os mesmos comandos Docker:

```
docker pull bkimminich/juice-shop
docker run --rm -d --name juice-shop-a02 -p 127.0.0.1:3000:3000 bkimminich/juice-shop
docker ps --filter name=juice-shop-a02
```

Acesso no navegador: `http://127.0.0.1:3000`. Encerramento: `docker stop juice-shop-a02`.

SEGURANÇA

O vínculo 127.0.0.1 mantém o laboratório na máquina do estudante. Não orientar 0.0.0.0, encaminhamento de porta ou uso da demonstração pública como alvo.

Checklist cinco minutos antes

Verificação	Pronto quando...	Se falhar...
Alvo	URL local abre e não está exposta à Internet	usar evidência alternativa
Estado	container reiniciado com dados fictícios	restaurar snapshot ou seguir offline
Projetor	texto e rodapés são legíveis	usar PDF local
Entrega	roteiro está acessível à turma	distribuir cópia local
Segurança	critério de parada e canal de aviso definidos	não iniciar a exploração

Verificação	Pronto quando...	Se falhar...
CRITÉRIO DE PARADA Interromper diante de destino divergente, dados reais, efeito fora do container, comportamento instável ou qualquer tentativa contra sistema público, institucional ou de terceiro.		

Organização da sala

Forme duplas. O investigador opera o navegador; o revisor confere o alvo, registra evidências e questiona inferências. Após a primeira observação, os papéis são trocados. Essa divisão evita que apenas quem usa a ferramenta participe e torna a contribuição individual observável.

2. Narrativa e conceitos essenciais

Contexto profissional ampliado

A empresa fictícia prepara uma demonstração comercial. Durante a revisão, alguém percebe que uma URL entrega um documento usado no processo de aquisição. Não se sabe ainda se houve publicação indevida, autorização ausente, erro de empacotamento ou apenas interpretação incorreta da finalidade do arquivo. Também não se sabe quem acessou, com que intenção ou por quanto tempo o recurso esteve disponível.

A equipe precisa decidir se interrompe a demonstração, remove o recurso, restringe o acesso ou apenas aumenta o monitoramento. Uma decisão apressada pode quebrar uma função legítima; uma decisão tardia pode prolongar a exposição. Por isso, o inventário e a consequência precedem a escolha do controle.

Modelo de resposta que o professor deve construir

Elemento	Pergunta	Exemplo no cenário
Evidência	o que ocorreu diretamente?	o servidor entregou o recurso naquela requisição
Ativo	o que possui valor ou sustenta a missão?	arquivo, dados, aplicação, rota e plataforma
Fraqueza	que condição pode originar falhas?	publicação indevida ou autorização insuficiente — ainda hipótese
Vulnerabilidade	qual instância concreta pode ser explorada?	recurso interno acessível fora da política esperada
Exposição	por qual caminho é alcançável?	rota HTTP servida pela aplicação
Ameaça	quem ou o que pode causar dano?	usuário não autorizado, erro operacional ou automação
Exploit	qual técnica usa a vulnerabilidade?	requisição construída; nem sempre exige código
Controle	como prevenir, limitar, detectar ou corrigir?	remover, autorizar, minimizar e monitorar

DISTINÇÃO CRÍTICA

CWE descreve classes de fraqueza. CVE identifica vulnerabilidades específicas publicadas. Não atribua um CVE ao desafio didático sem uma fonte que sustente a correspondência.

Transferência para OT

Ao comparar com uma HMI ou controlador, acrescente disponibilidade do processo, qualidade, ambiente e safety. A remoção imediata de um recurso ou isolamento de um componente pode reduzir risco cibernético e simultaneamente retirar visibilidade necessária ao estado seguro. A resposta deve envolver autoridade operacional e janela de manutenção.

3. Condução dos slides — 0 a 52 minutos

Tempo/slide	Ação do professor	Participação e evidência
0–5 • Slide 1	mostrar HTTP 200 sem diagnosticar; pedir o que a tela mostra e não mostra	duas observações; professor separa fato e interpretação no quadro
5–10 • Slide 2	apresentar papel profissional, alvo, restrições e entrega	turma repete o escopo e indica um critério de parada
10–17 • Slide 3	solicitar previsão individual antes da explicação	duas observações, um ativo, uma hipótese e uma lacuna
17–28 • Slide 4	construir inventário por função e consequência, incluindo OT	uma linha priorizada com justificativa
28–40 • Slide 5	classificar os termos usando sempre a mesma evidência	cadeia ativo–fraqueza–vulnerabilidade–exposição–ameaça
40–47 • Slide 6	votação argumentada: remover, autorizar ou monitorar	decisão com premissa e evidência de reteste
47–50 • Slide 7	demonstrar o ciclo confirmar–prever–observar–registrar–validar	previsão do resultado antes da requisição
50–52 • Slides 8–9	explicar produto, transição e síntese	duplas assumem papéis e abrem o roteiro

Falas e perguntas úteis

- Slide 1: “Leiam como analistas. Qual palavra da resposta é fato e qual conclusão vocês ainda não podem escrever?”
- Slide 3: “Que nova evidência faria você abandonar sua hipótese?”
- Slide 4: “Se retirarmos esse ativo, qual processo deixa de funcionar e quem percebe primeiro?”
- Slide 5: “A frase descreve uma classe de erro ou uma instância concreta em um produto?”
- Slide 6: “Complete: se a função do recurso for ____, escolhemos ____ e comprovamos por ____.”

O que não antecipar

- Não declarar a causa do acesso antes da observação da arquitetura.
- Não revelar caminhos adicionais, respostas de desafios ou uma sequência de cliques.
- Não aceitar “é vulnerável porque deu 200” como explicação completa.
- Não transformar a taxonomia em lista para memorização; cada termo deve responder a uma pergunta do caso.

4. Mediação da prática — 52 a 104 minutos

Tempo	Missão da dupla	Intervenção do professor	Evidência
52–64	subir container local e confirmar 127.0.0.1:3000	verificar Docker, nome, porta e vínculo local	container e URL local
64–69	confirmar alvo, papéis e hipótese	verificar endereço antes da observação	checklist e previsão
69–79	observar uma requisição sem enumerar	perguntar o que cada campo demonstra	registro sanitizado
79–87	inventariar recurso, aplicação/rota, dados e container	cobrar função, responsável e consequência	inventário do Juice Shop priorizado
87–96	produzir registro da vulnerabilidade	perguntar “observado ou inferido?” em cada afirmação	ticket preliminar
96–104	comparar tratamento, definir reteste e parar container	exigir premissa e confirmar docker stop	decisão e ambiente encerrado
101–104	revisão cruzada, limpeza e frase final	selecionar uma dúvida para a A03	PDF e ambiente encerrado

Pistas progressivas

Nível	Quando oferecer	Pista
1 • conceitual	dupla começa pela técnica	comece pelo substantivo que tem valor e pela função que ele sustenta
2 • observação	dupla mistura hipótese e fato	compare comportamento esperado e observado da mesma rota
3 • técnica	dupla não localiza a evidência	use a aba Network; observe método, caminho, status e tipo de conteúdo
alternativa	ambiente indisponível	use a resposta HTTP fictícia e não presuma conteúdo não mostrado

Como circular entre as duplas

Evite assumir o teclado. Leia uma frase do registro e pergunte qual evidência a sustenta. Se a dupla estiver bloqueada por infraestrutura, migre imediatamente para o pacote alternativo e avalie o raciocínio. Se estiver rápida demais, peça uma hipótese concorrente ou um teste que poderia produzir falso senso de correção.

REGRA DE EVIDÊNCIA

Captura de tela sem interpretação não comprova aprendizagem. Exija uma frase que diga o que a

imagem demonstra, o que não demonstra e como se relaciona à decisão.

5. Respostas esperadas e erros produtivos

Situação	Resposta aceitável	Intervenção docente
“200 prova invasão”	200 prova entrega naquela requisição	pedir evidência de intenção, autoria e política esperada
“o ativo é o servidor”	servidor é um ativo, mas arquivo, dados, aplicação e serviço também são	perguntar o que tem valor e qual função seria perdida
“a ameaça é a vulnerabilidade”	ameaça pode causar dano; vulnerabilidade é a instância explorável	pedir uma frase com sujeito, condição e consequência
“tem algum CVE”	não há base para atribuir CVE sem fonte específica	retomar diferença entre CVE e CWE
“basta retornar 404”	404 é uma evidência, mas o recurso pode só ter mudado de nome	pedir validação do processo de publicação e busca por equivalentes
“monitorar resolve”	monitoramento detecta, mas pode manter a exposição	perguntar que controle reduz a causa e qual risco residual permanece

Critérios de boa entrega

- Inventário associa ativos a função, responsável e consequência.
- Registro separa evidência, hipótese de fraqueza e conclusão.
- Prioridade é justificada por impacto, não pela flag ou facilidade técnica.
- Controle é condicionado à função do recurso e declara limitações.
- Reteste informa ação, resultado esperado e o que ainda pode produzir falso negativo.
- Entrega está sanitizada e respeita o escopo autorizado.

Extensão para grupos adiantados

Solicite uma consulta de inventário que encontre exposições semelhantes sem varrer redes: fonte de dados, responsável pela atualização, periodicidade e evidência de completude. Outra opção é pedir um teste negativo e um positivo para a autorização proposta.

6. Encerramento, avaliação e continuidade

Fechamento em três minutos

Escolha duas duplas e peça a frase: “Priorizamos o ativo ____ porque a consequência é ____.
Recomendamos ____ e validaremos por ____.” A turma deve identificar se a justificativa contém evidência, premissa e reteste.

Registro formativo do professor

Observe	Registre para a próxima aula
mistura entre ameaça, fraqueza e vulnerabilidade	exemplo que precisa ser retomado na A03
dificuldade em declarar lacunas	pergunta de abertura sobre hipótese concorrente
prioridade sem consequência	ativo que será reutilizado no modelo de ameaças
controle sem validação	teste de aceitação a ser incorporado ao próximo caso

Ponte para a A03

A A02 identifica ativos, exposições e consequências. A A03 pode reutilizar esse inventário para desenhar fronteiras de confiança, caminhos de ataque e registros de risco. Preserve apenas exemplos sanitizados e dúvidas conceituais; não leve respostas individuais para o material público.

Plano alternativo completo

Se o laboratório não funcionar, entregue a resposta fictícia do roteiro, o conjunto de ativos e a matriz de controles. As duplas ainda realizam previsão, inventário, classificação terminológica, registro, priorização e reteste proposto. Não penalize falha de infraestrutura: avalie a qualidade da evidência e do raciocínio.

Referências essenciais

- NIST Cybersecurity Framework 2.0 — categoria Asset Management (ID.AM).
- CWE — linguagem comum para fraquezas de software e hardware.
- CVE Program — identificação pública de vulnerabilidades específicas.
- OWASP Juice Shop — guia oficial de execução com Docker.
- Docker — instalação oficial do Docker Desktop para Windows e Docker Engine para Linux.